

Plantilla practica - Notas y Writeup para Rooms THM / CTF

Uso previsto: laboratorios autorizados, TryHackMe y CTF. Ajusta rutas, IPs, credenciales y herramientas segun el entorno.

Objetivo

Plantilla para no perder hallazgos mientras resuelves. La meta es que tus notas sirvan para continuar, explicar y escribir el writeup final.

Una buena nota responde: que vi, que probe, que salio, que desbloquea y donde esta la evidencia.

1. Estructura de carpeta

```
mkdir -p nmap web loot creds hashes screenshots exploits notes
touch notes/00-index.md notes/creds.md notes/commands.md notes/timeline.md
```

2. Ficha inicial

```
# Room
- Nombre:
- Plataforma: TryHackMe
- Fecha:
- IP:
- Hostnames:
- Dominio:
- Objetivo:
- VPN/AttackBox:
```

3. Tabla de superficie

Puerto	Servicio	Version	Evidencia	Siguiente prueba
80	HTTP	Apache/PHP	nmap_services.txt + whatweb	ffuf, Burp, vhosts
445	SMB	Windows/AD	nmap_ad.txt	shares, users, rid brute
22	SSH	OpenSSH	nmap_services.txt	probar creds/keys

4. Registro de comandos

```
## Comando
Fecha/hora:
Contexto:
Comando:
Resultado importante:
Archivo de evidencia:
Decision desbloqueada:
```

- No guardes cada linea de ruido; guarda outputs que cambian la decision.
- Si un comando falla, anota error y razon probable.

5. Credenciales

```
| Usuario | Password/Hash | Fuente | Servicio probado | Resultado |
| --- | --- | --- | --- | --- |
| user | pass | /var/www/config.php | ssh/smb/web | ssh OK |
```

- Separar credenciales confirmadas de candidatas.
- Anotar si una credencial abre nueva enumeracion.

6. Cadena de ataque

1. Recon: puertos abiertos y tecnologia.
2. Enumeracion: hallazgo clave.
3. Acceso inicial: vector exacto.
4. Post-exploit: usuario y permisos.
5. Privesc: misconfig explotada.
6. Flags: rutas y evidencia.
7. Root cause: por que funciono.

7. Plantilla de hallazgo

```
## Hallazgo
- Titulo:
- Impacto:
- Precondiciones:
- Evidencia:
- Pasos reproducibles:
- Comandos minimos:
- Resultado:
- Mitigacion teorica:
```

8. Checklist de cierre

- Tengo user.txt/root.txt o los objetivos de la room.
- Puedo reproducir acceso inicial con comandos minimos.
- Puedo explicar la escalada sin depender de output gigante de linpeas/winpeas.
- Credenciales y hashes estan etiquetados por fuente.
- El writeup no contiene secretos personales fuera del lab.
- Anote falsos caminos relevantes para no repetirlos.